

Risk Assessment Methodology

EMSPAKISTAN IT (PRIVATE) LIMITED

1. Purpose

The purpose of this document is to define the methodology used by EMSPAKISTAN IT (PRIVATE) LIMITED to identify, analyze, evaluate, and treat information security risks in alignment with ISO/IEC 27001:2022.

2. Scope

This methodology applies to all information assets, systems, processes, cloud environments, AI systems, and business operations within the scope of the ISMS.

3. Risk Management Approach

EMSPAKISTAN IT adopts a **risk-based approach** to information security, ensuring that risks are systematically identified, assessed, and treated based on their potential impact on the organization.

The methodology follows these steps:

- Asset Identification
 - Threat Identification
 - Vulnerability Identification
 - Risk Analysis
 - Risk Evaluation
 - Risk Treatment
-

4. Asset Identification

Assets include all resources that have value to the organization, such as:

- Client data and databases
- Cloud infrastructure and servers
- Web and mobile applications
- AI models and datasets
- Source code repositories
- Employee devices and internal systems

5. Threat Identification

Threats are potential events that may exploit vulnerabilities, including:

- Cyber attacks (e.g., hacking, DDoS, malware)
- Insider threats
- Data breaches and leakage
- Phishing and social engineering
- System failures and outages

6. Vulnerability Identification

Vulnerabilities are weaknesses that may be exploited by threats, such as:

- Weak passwords or lack of MFA
- Misconfigured cloud settings
- Lack of encryption
- Unpatched systems
- Lack of employee awareness

7. Risk Analysis

Each risk is analyzed based on two key factors:

- **Impact** – The potential damage to the organization
- **Likelihood** – The probability of the risk occurring

8. Risk Calculation

Risk score is calculated using the following formula:

Risk Score = Impact × Likelihood

Where:

- Impact is rated from 1 (Low) to 5 (Critical)
 - Likelihood is rated from 1 (Rare) to 5 (Almost Certain)
-

9. Risk Rating Criteria

Risk Score	Risk Level
1 – 5	Low
6 – 10	Medium
11 – 25	High

10. Risk Evaluation

Risks are evaluated based on their score:

- **High Risks** → Immediate action required
- **Medium Risks** → Planned mitigation required
- **Low Risks** → May be accepted with monitoring

11. Risk Treatment Options

The organization applies the following treatment strategies:

- **Mitigate** – Implement controls to reduce risk
- **Accept** – Accept the risk with justification
- **Transfer** – Shift risk to third parties (e.g., cloud providers)
- **Avoid** – Eliminate the risk by changing processes

12. Control Selection

Controls are selected based on ISO/IEC 27001 Annex A, including:

- Access Control (A.9)
 - Cryptography (A.10)
 - Operations Security (A.12)
 - Network Security (A.13)
 - Supplier Security (A.15)
-

13. Risk Register Maintenance

All identified risks are recorded in the Risk Register, which includes:

- Asset
- Threat
- Vulnerability
- Risk Score
- Treatment Plan

The Risk Register is updated regularly to reflect changes in the environment.

14. Review and Monitoring

- Risk assessments are conducted annually or after significant changes
 - High risks are reviewed quarterly
 - Continuous monitoring is performed to detect new threats
-

15. Roles and Responsibilities

- **Management** – Approves risk decisions
 - **IT Team** – Implements controls
 - **GRC Function** – Oversees risk management process
 - **Employees** – Follow security policies
-

16. Continuous Improvement

The organization ensures continuous improvement of its risk management process through:

- Internal audits
 - Incident analysis
 - Management reviews
 - Feedback and corrective actions
-

17. Conclusion

This Risk Assessment Methodology ensures a structured and consistent approach to identifying and managing information security risks at EMSPAKISTAN IT (PRIVATE) LIMITED, enabling effective protection of information assets and alignment with ISO/IEC 27001:2022 standards.
